

AN ECLECTIC TECHNOLOGIES REPORT

SCRM Companion Agent

AI-Enhanced Supply Chain Risk Management for Critical Infrastructure Protection

Version 1.2 · September 2026

Tim Roxey

Eclectic Technologies

tim.roxey@gmail.com · 410.474.9240 (mobile/Signal)

SUGGESTED CITATION

T. Roxey, "SCRM Companion Agent," Version 1.2, Eclectic Technologies, September 2026.

Concept DOI: <https://doi.org/10.5281/zenodo.21365261>

Version DOI (this version): <https://doi.org/10.5281/zenodo.22772172>

Executive Summary

The SCRM Companion Agent system addresses the critical challenge of supply chain risk management in bulk power systems by integrating artificial intelligence. This document presents the multi-agent architecture, operational use cases, pilot program structure, and governance framework for deploying AI-enhanced hardware and software bill-of-materials tracking and vulnerability-assessment capabilities within electric utility procurement and engineering operations.

The system deploys six specialized generative AI agents that integrate with existing utility enterprise systems, including procurement, inventory control, configuration management, and operations/maintenance platforms. These agents provide automated continuous visibility into hardware and software components deployed across operational technology environments, reducing vulnerability assessment time from weeks to minutes while enabling proactive risk identification before threats emerge.

A carefully structured pilot program using mock scenario methodology enables risk-free validation before production deployment, while a multi-stakeholder governance framework ensures industry coordination, technical excellence, and sustainable adoption. This initiative complements the ERT Companion system, with both efforts benefiting from shared infrastructure—including the Data Source Integration Toolkit and common deployment expertise.

Key Capabilities

- **Continuous HBOM/SBOM Visibility:** Automated, real-time hardware and software bills of materials tied to engineering designs and operational deployments
- **Rapid Vulnerability Assessment:** Reduce exposure assessment time from days or weeks to minutes when critical vulnerabilities are disclosed
- **Proactive End-of-Life Management:** Shift from annual reactive planning cycles to continuous monitoring of component support status
- **Counterfeit Detection:** Extend authentication checks from point-of-receipt inspection to continuous supply chain monitoring
- **CIP-013 Compliance Automation:** Automate evidence compilation for Supply Chain Risk Management audits across procurement, engineering, and operations
- **ERT Companion Integration:** Share infrastructure, governance, and deployment expertise with the ERT Companion for coordinated compliance automation

Program Overview

Strategic Context

Electric utilities face escalating supply chain security challenges as operational technology systems become targets of sophisticated cyberattacks. The SolarWinds breach, the Colonial Pipeline incident, and numerous other supply-chain compromises demonstrate that adversaries increasingly target vendors and components rather than directly attacking hardened utility defenses. Meanwhile, the proliferation of vulnerabilities in industrial control system components creates continuous exposure assessment requirements that overwhelm manual processes.

Current supply chain risk management approaches rely on periodic audits, manual procurement reviews, and disconnected data systems that prevent timely risk identification. When critical vulnerabilities like Log4j are disclosed, utilities spend weeks manually searching procurement records, inventory databases, and configuration documentation to determine exposure. This reactive approach creates windows of vulnerability in which threats evolve faster than assessment and remediation can respond—the strategic compression challenge in which defensive timescales cannot match offensive timescales.

NERC CIP-013 Supply Chain Risk Management standards establish requirements for utilities to identify and assess cybersecurity risks associated with supply chain vendors and procured products and services. However, the standards do not prescribe specific technical implementations, leaving utilities to develop diverse approaches with varying effectiveness. The SCRM Companion Agent system provides a comprehensive technical framework that enables utilities to meet and exceed regulatory requirements while building operational capabilities that serve broader engineering and security functions.

System Scope and Purpose

The SCRM Companion Agent system comprises six specialized artificial intelligence agents that collaborate to provide comprehensive visibility into supply chain risk. Each agent focuses on a specific domain—inventory management, vulnerability intelligence, procurement tracking, configuration management, operations/maintenance intelligence, or integration coordination—while sharing data through common knowledge representations and coordinated workflows.

The system integrates with utility enterprise systems that already contain supply chain information but are not currently leveraged for continuous risk assessment. Procurement systems track vendor relationships, purchase orders, and component specifications. Inventory control systems maintain custody chains and storage locations. Configuration management databases document as-built system architectures and component deployments. Operations and maintenance systems record component performance, failures, and replacements. The SCRM agents extract, correlate, and analyze information from these disconnected sources to build comprehensive hardware and software bills of materials tied to engineering designs and operational deployments.

The system is explicitly designed to complement the ERT Companion system. While ERT Companion automates compliance evidence collection, SCRM Companion provides the supply chain intelligence that supports both compliance requirements and broader operational risk management. The two systems can be deployed together or separately, share common infrastructure through the Data Source Integration Toolkit, and benefit from coordinated governance through their respective steering committees.

Governance and Organizational Framework

The SCRM Companion operates within a governance framework that parallels the ERT Companion structure and reflects the distinct stakeholder communities involved in supply chain risk management and regulatory compliance. This framework is detailed in the companion document Governance and Organizational Structure, with SCRM-specific adaptations summarized here.

Four primary participants collaborate on program development and deployment. NERC alignment is a program objective. The pilot is designed to demonstrate CIP-013 compliance value in a way that can be brought to NERC and Regional Entities for broader ERO Enterprise endorsement once the evidence base is established. EEI Working Group engagement is a longer-term program objective. In the current phase, industry coordination is provided through the steering committee, which includes ICS supplier colleagues with procurement and supply chain domain expertise alongside participating utility representatives. Eclectic Technologies provides technical expertise in AI agent development, supply chain intelligence, and critical infrastructure cybersecurity. Volunteer utilities host pilot deployments and provide operational perspectives that ground development in real-world procurement and engineering constraints.

A small steering committee provides strategic oversight with representation from Eclectic Technologies, ICS supplier colleagues with supply chain and procurement domain expertise, and utility personnel including supply chain/procurement representatives and engineering managers. This committee ensures that SCRM capabilities address genuine operational needs while maintaining alignment with regulatory expectations and guides program direction as deployments proceed.

Decision-making authority follows the same distributed model as ERT Companion. Regulatory alignment with CIP-013 requirements is maintained through the program's design principles and will be validated through pilot outcomes. Requirements for SCRM agent features are driven through the steering committee consensus process, with input from ICS supplier colleagues and participating utilities. Technical implementation decisions remain with Eclectic Technologies, subject to established requirements and strategic direction. This governance model recognizes that while SCRM has regulatory dimensions through CIP-013, its primary value lies in operational risk reduction and engineering intelligence that extends well beyond compliance.

The intellectual property model mirrors ERT Companion. Eclectic Technologies retains ownership but licenses tools at no cost to utilities. As the program matures, both EEI and NERC may be engaged to distribute tools more broadly to support industry adoption. This eliminates procurement

friction while maintaining quality standards and enabling ongoing development. Utilities retain full sovereignty over their procurement data, vendor relationships, and component inventories, with appropriate confidentiality protections that ensure competitive information remains secure.

Expansion follows an organic growth model. Initial pilots proceed sequentially with early adopter utilities, allowing each installation to inform improvements to both SCRM agent capabilities and the shared Data Source Integration Toolkit. Utilities deploying both ERT Companion and SCRM Companion benefit from shared infrastructure and coordinated installation, while those choosing only one system still realize full value from that deployment.

Multi-Agent Architecture

Architectural Rationale

The SCRM system employs a multi-agent architecture rather than a single monolithic AI system because supply chain risk management requires diverse capabilities, data integration patterns, and analytical approaches. Different supply chain functions involve different enterprise systems, require different domain expertise, and serve different stakeholder communities. A procurement specialist querying vendor risk profiles requires different capabilities than an engineering manager assessing firmware vulnerability exposure or a maintenance technician tracking component replacement history.

Specialized agents focus on distinct aspects of supply chain risk management while collaborating through shared data models and coordinated workflows. This approach recognizes that different functions require different capabilities, enabling independent development, testing, and deployment of each agent. Failure of one agent does not compromise the entire system. Agents can evolve at different rates as capabilities mature and new requirements emerge. The architecture also supports phased deployment, where utilities can implement high-priority agents first and add additional agents as resources and needs dictate.

HBOM/SBOM Inventory Agent

The HBOM/SBOM Inventory Agent maintains comprehensive hardware and software bills of materials for deployed systems. This agent integrates with procurement databases, configuration management systems, inventory tracking systems, and engineering design documentation to build detailed component inventories. The agent understands that complex equipment such as protective relays or SCADA servers comprises multiple constituent components—chassis, processor boards, communication modules, firmware, embedded software libraries, and operating systems—each with its own manufacturer, model number, version, and security characteristics.

When procurement records indicate a relay purchase, the agent queries manufacturer databases and specification sheets to decompose the relay into constituent components and trace each component's provenance through the supply chain. As firmware updates are applied or hardware modules are replaced during maintenance, the agent updates the inventory to reflect current configurations. The agent maintains relationships between components and their deployment locations, tracking which relay is installed in each substation bay and which firmware version is running.

The HBOM/SBOM representation includes not only component identities but also metadata on procurement dates, warranty periods, end-of-life schedules, support availability, and known vulnerabilities. This contextual information enables proactive risk management before vulnerabilities emerge—for example, by identifying components approaching end-of-life or no longer receiving security updates.

Vulnerability Intelligence Agent

The Vulnerability Intelligence Agent monitors vulnerability databases, security advisories, and threat intelligence feeds to identify newly disclosed vulnerabilities affecting components in the utility's inventory. This agent integrates with sources including the National Vulnerability Database, ICS-CERT advisories, vendor security bulletins, Information Sharing and Analysis Centers, and commercial threat intelligence platforms.

When a new vulnerability is disclosed, the agent maps the affected software or hardware to the utility's component inventory through collaboration with the HBOM/SBOM Inventory Agent. The mapping addresses the challenge that vulnerability advisories may reference software libraries, firmware components, or hardware revisions that use different naming conventions from procurement or inventory records. The agent uses natural language understanding and knowledge of component relationships to correlate vulnerability references with inventory entries.

The agent assesses vulnerability severity based on how components are deployed and used. A vulnerability in internet-facing systems might have a lower practical impact if the affected component operates on an isolated network without external connectivity. The agent considers deployment context, network architecture, and compensating controls when prioritizing vulnerabilities for remediation. When high-severity vulnerabilities are identified, the agent generates exposure assessments showing which facilities are affected, which systems are at risk, and what remediation actions are required.

Procurement Intelligence Agent

The Procurement Intelligence Agent tracks component acquisitions from initial requisition through delivery and deployment. This agent integrates with procurement systems, vendor management platforms, and contract databases to maintain a comprehensive understanding of vendor relationships, procurement timelines, and component sources.

The agent monitors vendor risk profiles, tracking security incidents involving vendors, changes in vendor ownership or financial status, and geopolitical factors that might affect vendor reliability or security posture. When procurement decisions are made, the agent can provide risk assessments that compare alternative vendors based on security track records, supply chain transparency, and past performance. The agent also tracks procurement compliance with CIP-013 requirements, flagging purchases that lack required supply chain risk assessments or vendor agreements.

For components already deployed, the agent maintains a historical procurement context showing when components were purchased, which purchase orders they were part of, and which vendor representatives were involved. This historical context supports forensic analysis if supply chain compromises are later discovered, enabling utilities to identify potentially affected components based on procurement timeframes or vendor relationships.

Configuration Management and Engineering Design Agent

The Configuration Management and Engineering Design Agent correlates deployed component configurations with original engineering specifications and design intent. This agent integrates with configuration management databases, engineering design repositories, and as-built documentation to ensure that what is actually deployed matches what was designed and approved.

The agent understands engineering design hierarchies showing how individual components fit into subsystems, how subsystems integrate into larger systems, and how systems support operational functions. When assessing vulnerability exposure or planning component replacements, the agent can identify system dependencies and operational impacts. The agent also tracks configuration changes over time, identifying when deployed configurations diverge from baseline designs and whether those divergences were properly authorized and documented.

This agent supports change management processes by assessing proposed changes against system architectures and identifying potential supply chain security implications. If a proposed firmware update or component replacement introduces new vendors or changes component sourcing, the agent flags this for supply chain risk assessment before the change is approved.

Operations and Maintenance Intelligence Agent

The Operations and Maintenance Intelligence Agent tracks component performance history, maintenance activities, and operational anomalies that might indicate supply chain security issues. This agent integrates with work order systems, maintenance management platforms, SCADA historians, and equipment monitoring systems.

The agent maintains equipment lifecycle tracking showing installation dates, maintenance history, performance trends, and failure patterns. Unusual component behavior might indicate compromised firmware or counterfeit hardware. The agent correlates maintenance activities with component changes, ensuring that work orders properly document component replacements and that replaced components are tracked through disposal processes as required by CIP regulations.

The agent also supports predictive maintenance by identifying components exhibiting early failure indicators or performance degradation that may require replacement. When replacements are planned, the agent provides current HBOM information to procurement teams and validates that replacement components meet original specifications and security requirements.

Integration and Coordination Agent

The Integration and Coordination Agent serves as the central coordinator, enabling the other five agents to collaborate effectively. This agent maintains the shared knowledge graph, in which each specialized agent contributes its domain-specific information while querying others' information. The agent handles complex queries that require integrated analysis across multiple domains, orchestrating information gathering from relevant specialized agents and synthesizing results into coherent responses.

When a user queries "What is our exposure to the newly disclosed vulnerability CVE-2025-XXXX?", the Integration Agent coordinates with the Vulnerability Intelligence Agent to understand the vulnerability details, queries the HBOM/SBOM Inventory Agent to identify affected components, works with the Configuration Management Agent to determine where those components are deployed, and collaborates with the Procurement Intelligence Agent to identify when affected components were purchased and which vendors supplied them. The integrated response provides a comprehensive exposure assessment that no single specialized agent could produce independently.

This agent also manages the natural language interface that utility personnel use to interact with the system, translating user queries into agent orchestration plans and presenting results in formats appropriate to different user communities—procurement specialists receive vendor-focused analyses, engineering managers see system architecture perspectives, and security teams get vulnerability-centric views of the same underlying information.

Six-Agent Architecture at a Glance

- **HBOM/SBOM Inventory Agent** — comprehensive hardware and software bills of materials linked to procurement, configuration, and deployment records
- **Vulnerability Intelligence Agent** — continuous monitoring of vulnerability databases, ICS advisories, and threat feeds mapped to the component inventory
- **Procurement Intelligence Agent** — vendor risk profiling, procurement compliance tracking, and supply chain traceability from requisition to deployment
- **Configuration Management and Engineering Design Agent** — as-deployed vs. as-designed correlation, change management support, and configuration baseline integrity
- **Operations and Maintenance Intelligence Agent** — lifecycle tracking, anomaly detection, and predictive maintenance support with HBOM-linked replacement guidance
- **Integration and Coordination Agent** — shared knowledge graph, multi-agent query orchestration, and natural language interface for all user communities

Technical Integration Architecture

Data Source Integration

The SCRM Companion Agent system leverages the same Data Source Integration Toolkit used by the ERT Companion system, demonstrating synergies between the two initiatives. The toolkit provides standardized mechanisms for connecting to utility enterprise systems, mapping data schemas, validating connectivity, and managing credentials with appropriate security controls.

SCRM agents integrate with enterprise systems that contain supply chain information. The procurement system provides vendor information, purchase orders, contracts, and procurement approvals. The inventory control system maintains component custody chains, storage locations, and stock levels. The configuration management database documents as-built system architectures, component deployments, and configuration baselines. The work order system tracks maintenance activities, component replacements, and disposal processes. The vendor management platform maintains vendor risk assessments, security questionnaires, and performance histories. The asset management system links components to physical facilities and operational systems.

For utilities deploying both ERT Companion and SCRM Companion, the Data Source Integration Toolkit provides a unified interface to shared data sources. Configuration management databases serve both compliance evidence needs and supply chain tracking. Work order systems support both audit evidence and maintenance intelligence. Asset management systems populate both ERT detail tabs and HBOM inventories. This shared infrastructure reduces the total deployment effort and enables cross-system validation, in which the same information viewed through different lenses provides mutual verification.

Security Architecture

The SCRM system implements security controls appropriate for sensitive procurement and vendor information. Role-based access controls ensure that users see only information relevant to their functions—procurement specialists access vendor risk profiles, engineering managers view component configurations, maintenance technicians see equipment histories, and security analysts query vulnerability exposures. Comprehensive audit logging tracks all data accesses and agent queries, supporting both security monitoring and compliance verification.

Data sovereignty remains with the utility. Vendor relationships, procurement negotiations, pricing information, and strategic sourcing plans remain confidential. The system architecture supports on-premises deployment, where all data remains within utility infrastructure, or hybrid architectures where some processing occurs in secure cloud environments while sensitive data remains on-premises. The system is subject to the Companion Quality Assurance Framework, evaluating both infrastructure security and AI-specific risks consistent with the approach applied across the Companion suite.

Integration with ERT Companion

SCRM Companion and ERT Companion systems are designed for complementary deployment. Both systems benefit from shared infrastructure—including the Data Source Integration Toolkit, common security frameworks, and coordinated governance through their respective steering committees. Deployment teams gain expertise applicable to both systems, reducing the learning curve for utilities implementing both capabilities.

From a regulatory perspective, SCRM provides supply chain intelligence that supports evidence of compliance with CIP-013. When ERT Companion needs to demonstrate supply chain risk management processes for audit purposes, it can draw on evidence automatically generated by SCRM agents. Conversely, when SCRM agents identify supply chain risks requiring remediation, those remediation activities generate configuration changes and procurement actions that ERT Companion tracks to ensure compliance.

The systems can be deployed together in coordinated installations where deployment teams configure both sets of agents simultaneously, or separately, where utilities prioritize one capability and add the other later. The shared Data Source Integration Toolkit ensures that connectivity work performed for one system benefits the other, whether deployments are concurrent or sequential.

Operational Use Cases

The following use cases demonstrate SCRM Companion's value across procurement, engineering, security operations, and regulatory compliance contexts. These scenarios are conducted in a controlled pilot environment using mock-scenario methodology, enabling comprehensive validation without operational risk.

Emergency Vulnerability Response

Actor: Jennifer Martinez, Principal Cybersecurity Engineer, Southwest Regional Energy

At 3:45 PM on a Friday, CISA issues an emergency directive regarding a critical zero-day vulnerability (CVE-2025-5678) affecting multiple firmware versions in Schweitzer Engineering Laboratories (SEL) protective relays. The vulnerability allows remote code execution through crafted network packets and is being actively exploited against electric utilities. Jennifer's team must rapidly assess exposure across the company's 200+ substations and coordinate emergency mitigation before the weekend, when staffing is reduced and adversaries often intensify attacks.

Under traditional processes, Jennifer would coordinate with multiple departments over several days: the procurement team searching historical purchase orders, the engineering design group reviewing one-line diagrams, the configuration management team searching databases for firmware version information, and field operations dispatched to verify firmware versions on substations. This multi-day process would leave the utility exposed to active exploitation for 72+ hours.

System Interaction:

Jennifer opens the SCRM Companion interface and queries: "Show me all SEL protective relays affected by CVE-2025-5678 and their current firmware versions." The Integration Agent coordinates with the Vulnerability Intelligence Agent to understand which relay models and firmware versions are affected, queries the HBOM/SBOM Inventory Agent to identify deployed relays, and works with the Configuration Management Agent to retrieve current firmware version information. Within 90 seconds, the system returns a comprehensive exposure assessment: 47 relays at 23 substations are running vulnerable firmware versions, with complete details on specific relay models, firmware versions, substation locations, and system functions protected by each relay.

Jennifer queries for operational context: "For the affected relays, identify any that protect transmission lines critical for regional reliability." The Configuration Management Agent retrieves engineering design information showing system dependencies. The analysis identifies 8 relays protecting critical 345kV transmission interties where remote code execution could enable adversaries to manipulate protection settings and potentially trigger cascading failures. These relays are prioritized for immediate emergency mitigation.

Jennifer requests remediation planning support: "What mitigation options are available while we plan firmware updates?" The Vulnerability Intelligence Agent retrieves CISA's mitigation guidance, and the Configuration Management Agent identifies network architecture options. The system

recommends temporarily isolating relay communication networks from corporate networks to prevent remote exploitation while maintaining relay operation, and provides specific implementation guidance for the utility's network architecture.

Outcome:

Jennifer completes the exposure assessment in under 2 hours rather than 3+ days, enabling emergency mitigation to begin Friday evening rather than Monday or Tuesday. This faster response directly reduces the window for vulnerability exploitation during the high-risk weekend period. The comprehensive exposure assessment ensures no affected relays are overlooked. The system-generated remediation plan accounts for the utility's specific network architecture and operational constraints. In the mock scenario environment, this validates that SCRM capabilities can support emergency response timelines that match threat actor operational tempos.

Proactive End-of-Life Component Management

Actor: Robert Chen, Senior Engineering Manager, Midwest Electric Cooperative

Robert is responsible for long-term asset management planning for the cooperative's substation automation systems. Industry trends show increasing vendor consolidation, with several equipment manufacturers discontinuing product lines or being acquired by competitors. Components reaching end-of-life present multiple risks: discontinued security updates create vulnerability exposure, lack of spare parts threatens operational reliability, and emergency replacements under time pressure may involve less secure procurement processes that bypass normal vendor risk assessments.

Under traditional approaches, Robert's team conducts annual reviews where engineers manually compile equipment inventories from multiple databases, research vendor support policies, and develop replacement plans. This annual cadence means that components can reach end-of-life status unexpectedly between planning cycles, forcing reactive responses. The manual process also struggles to account for software dependencies in which an operating system or application software reaches end-of-life before the underlying hardware, creating security risks even when the hardware remains functional.

System Interaction:

Robert queries: "Identify all hardware and software components in substation automation systems that will reach end-of-life or end-of-support within the next 24 months." The HBOM/SBOM Inventory Agent retrieves comprehensive component listings. The Procurement Intelligence Agent queries vendor support databases and tracks vendor announcements about discontinued products. The Vulnerability Intelligence Agent identifies components no longer receiving security updates.

The system identifies 34 remote terminal units (RTUs) running an embedded Linux distribution that reaches end-of-support in 18 months, 12 substation gateway routers whose manufacturer was recently acquired and whose future support is uncertain, and 7 historian servers running database

software versions no longer receiving security patches. Each finding includes deployment locations, system dependencies, and current operational status.

Robert requests replacement planning support: "For the RTUs reaching end-of-support, what are the approved replacement options and estimated costs?" The Procurement Intelligence Agent retrieves information on vendor-qualified replacement RTUs that meet the utility's standards, including pricing from recent procurements and the status of vendor security assessments. The Configuration Management Agent identifies RTU communication interfaces and protocol requirements that replacement units must support.

Robert queries for prioritization guidance: "Which end-of-life components present the highest operational or security risk?" The Integration Agent synthesizes risk assessments across all agents. Historian servers running unsupported database software pose an immediate security risk because they aggregate data from multiple substations and connect to corporate networks. The RTUs have longer lead times before support ends but replacement requires complex engineering. The gateway routers present uncertainty risk due to unclear vendor support commitments post-acquisition. This risk-informed prioritization enables Robert to allocate resources effectively across the 24-month planning horizon.

Outcome:

Robert shifts from annual reactive planning to continuous proactive management. Components reaching end of life are identified early enough to plan orderly replacements through proper procurement processes and vendor risk assessments. Budget planning accounts for replacement costs spread across multiple fiscal years, reducing the risk of surprise budget impacts. The cooperative avoids emergency replacements under time pressure, which often bypass security review processes. The mock scenario validates that SCRM capabilities enable strategic asset management rather than just tactical risk response.

Counterfeit Component Detection

Actor: Lisa Thompson, Procurement Quality Manager, Eastern Utilities Group

Lisa manages procurement quality assurance for a multi-state utility holding company. Industry reports document increasing incidents of counterfeit components entering utility supply chains, including relays with fraudulent certification markings, network equipment with unauthorized firmware modifications, and hardware sold through unauthorized distribution channels. Counterfeit components pose multiple risks: unreliable operation that threatens service reliability, lack of genuine security patches, increased vulnerability, and unknown backdoors or malicious modifications introduced during manufacturing or distribution.

Traditional counterfeit detection relies primarily on physical inspection of received equipment, verification of serial numbers against manufacturer databases, and periodic audits of vendor documentation. These controls operate primarily at the point of receipt, after procurement

commitments have been made and components have entered the supply chain. Detection after deployment is even more difficult because components are already installed in operational systems.

System Interaction:

Lisa configures the Procurement Intelligence Agent to continuously flag suspicious procurement patterns: orders from previously unknown vendors, pricing significantly below market rates, vendors located in high-risk geographic regions, or equipment offered through unauthorized distribution channels.

The system flags a recent order for network switches from a vendor offering prices 40% below authorized distributors. The Procurement Intelligence Agent queries manufacturer databases and determines that the vendor is not an authorized distributor. The HBOM/SBOM Inventory Agent notes that the ordered switch model has unique firmware signing requirements that counterfeit units often lack. Lisa's team requests detailed vendor documentation and authenticates the procurement through the manufacturer's authorized channels, discovering that the original order would have delivered counterfeit equipment.

For equipment already deployed, Lisa queries: "Analyze firmware signatures on all network equipment and identify any that fail cryptographic verification or do not match manufacturer published hashes." The Configuration Management Agent retrieves firmware information from deployed equipment. The HBOM/SBOM Inventory Agent compares firmware hashes against manufacturer databases. The analysis identifies three switches at a single facility for which firmware signatures cannot be verified against manufacturer records. Further investigation reveals that these switches were procured five years ago from a vendor that is no longer in business, raising concerns about equipment authenticity.

Lisa requests supply chain traceability: "For the switches with unverifiable firmware, trace their procurement history and identify similar purchases that might present comparable risk." The Procurement Intelligence Agent reconstructs the procurement history, identifies the defunct vendor, and finds six other equipment purchases from the same vendor over two years. All seven procurements are flagged for detailed authenticity verification, with field inspections scheduled to verify hardware serial numbers and component markings.

Outcome:

Lisa shifts counterfeit detection from post-receipt inspection to continuous supply chain monitoring across procurement, deployment, and operations phases. Suspicious procurement patterns are identified before orders are placed. Deployed equipment undergoes ongoing authenticity verification rather than a one-time inspection at receipt. Historical procurement patterns enable proactive identification of at-risk equipment rather than waiting for operational failures to reveal counterfeit components. The mock scenario demonstrates that SCRM capabilities support the verification of supply chain integrity at enterprise scale.

CIP-013 Compliance Documentation

Actor: Michael Foster, Manager of Regulatory Compliance, Northern Grid Services

Michael's utility is preparing for an upcoming NERC CIP compliance audit that will include a detailed examination of CIP-013 Supply Chain Risk Management implementation. The auditors will request evidence demonstrating that the utility has implemented supply chain cybersecurity risk management plans, conducted vendor risk assessments, obtained supply chain cybersecurity risk management plans from vendors, verified that procured products and services meet specifications, and maintained documentation of all supply chain risk management activities.

Under traditional processes, Michael's team would spend several weeks manually compiling evidence from disconnected sources. Procurement would provide vendor contracts and risk assessment questionnaires. Engineering would supply equipment specifications and acceptance test reports. IT security would contribute vendor security incident records. Legal would provide contract language about security requirements. Synthesizing these disparate sources into coherent audit evidence packages requires extensive manual effort and introduces the risk that required evidence may be overlooked.

System Interaction:

Michael queries: "Generate a complete evidence package for CIP-013 Requirement R1 showing our supply chain cybersecurity risk management plan and its implementation for all procurements made during the audit period." The Integration Agent coordinates across all six specialized agents to gather relevant information.

The Procurement Intelligence Agent provides the supply chain cybersecurity risk management plan that governs procurement processes, vendor risk assessment templates, and records of plan reviews and updates. For each procurement during the audit period, the agent supplies vendor risk assessments, procurement approvals documenting risk considerations, and contracts that include supply chain security requirements. The HBOM/SBOM Inventory Agent provides inventory records showing which components were procured and deployed. The Configuration Management Agent provides acceptance test documentation that verifies that components meet specifications. The Vulnerability Intelligence Agent provides records of ongoing vulnerability monitoring for procured components, demonstrating continuous risk assessment post-procurement.

Michael reviews the automatically compiled evidence and identifies a few procurements in which vendor risk assessments used older templates that do not fully address the current threat landscape. He queries: "For procurements with older vendor risk assessment templates, generate updated assessments using current templates and identify any new risks that should be documented." The Procurement Intelligence Agent retrieves current vendor information and generates updated risk assessments, flagging two vendors who experienced security incidents since the original assessments were completed. Michael's team documents these findings and the compensating controls that were already in place.

Michael requests cross-functional validation: "Compare our supply chain risk management documentation against ERT Companion evidence for configuration management, change control,

and vendor management to identify any inconsistencies." The query identifies three cases in which procurement records show component replacements without corresponding change management documentation in ERT Companion. The investigation reveals that the replacements were like-for-like maintenance activities that engineering teams classified as maintenance rather than as changes requiring formal change management. Michael's team clarifies the documentation to explain the classification rationale, strengthening both supply chain and change management audit evidence.

Outcome:

Michael completes CIP-013 evidence compilation in days rather than weeks. The evidence is comprehensive, internally consistent, and traceable to authoritative sources. Cross-validation between SCRM and ERT Companion evidence reduces audit risk by identifying documentation gaps before auditors discover them. The automated evidence compilation also supports ongoing compliance activities by enabling quarterly self-assessments rather than responding solely to audit notifications. The mock scenario demonstrates that SCRM capabilities support both operational supply chain risk management and regulatory compliance documentation requirements.

Mock Scenario and Pilot Program Structure

Pilot Program Rationale

The mock scenario approach provides a controlled environment for comprehensive system validation before production deployment. This methodology enables rigorous testing of both technical capabilities and business process integration while eliminating operational risk for participants.

Most fundamentally, mock scenario results carry no operational impact. They do not affect actual procurement decisions, vendor relationships, or operational systems. Any system failures or data quality issues discovered during testing have no bearing on supply chain security posture or regulatory compliance status. This protection allows both utility and vendor participants to experiment with system capabilities without fear of inadvertent consequences.

The utility maintains full rollback capability throughout the pilot duration. If the prototype system proves unreliable or fails to meet operational requirements, the utility can continue to use existing supply chain risk management processes without disruption. This fallback option eliminates the risk that pilot participation could compromise operational supply chain security or regulatory compliance.

The controlled pilot environment—with its protective mechanisms of no operational impact, full rollback capability, and staged validation—allows participants to rigorously test both technical capabilities and business process integration before production deployment. This comprehensive validation addresses stakeholder concerns about disrupting established procurement and engineering workflows while building confidence in the system's ability to enhance both operational effectiveness and regulatory compliance.

Mock Scenario Definition

The mock scenario simulates comprehensive supply chain risk management activities across the full range of utility procurement and engineering operations. The scenario uses historical data from recent procurements and deployments, allowing direct comparison with actual supply chain risk management activities while eliminating operational risk.

The simulated utility maintains a representative portfolio of procurements, including protective relays, SCADA equipment, network infrastructure, physical security systems, and enterprise IT systems that support BES Cyber Systems. The procurement portfolio spans multiple vendors, includes both hardware and software components, and reflects the full range of CIP impact classifications from high-impact BES Cyber Systems to low-impact systems.

To ensure the mock scenario adequately tests the system's capabilities, it incorporates complexity and edge cases that commonly arise in real-world supply chain risk management. These include vendor acquisitions or ownership changes during the scenario period; the discovery of vulnerabilities in deployed equipment that require emergency response; procurement decisions

involving alternative vendors with different risk profiles; component obsolescence requiring replacement sourcing; and potential counterfeit-detection scenarios. If possible, the pilot selects a utility with geographically diverse operations to validate the system's ability to track supply chains across multiple regions and regulatory jurisdictions.

Pilot Program Phases

The nine-month pilot program proceeds through carefully sequenced phases that enable progressive validation and early course correction if issues emerge. The phases parallel those developed for ERT Companion while adapting to SCRM-specific requirements.

Phase	Timeline	Key Activities
Phase 1	Months 1–2	Pilot Design and Preparation • Participant selection through the steering committee • Memorandum of understanding documenting roles and responsibilities • Mock scenario finalization with supply chain subject-matter experts • Data protection protocols for vendor and procurement confidentiality • Development environment configuration with security controls • Baseline metrics collection for current supply chain risk assessment effort
Phase 2	Months 3–4	Data Integration Development • Data schema mapping for procurement, inventory, configuration management, and operations/maintenance systems • Connection programs developed with authentication and error handling • Data quality validation frameworks for completeness and accuracy • HBOM/SBOM inventory populated from historical data and validated • Iterative refinement as data quality issues are identified and resolved
Phase 3	Months 5–6	Agent Development and Integration

		• Six specialized agents deployed and individually validated • Multi-agent coordination through the Integration Agent • Vulnerability Intelligence Agent connected to threat feeds and tested • Natural language query interfaces tested with procurement, engineering, and security user communities • User acceptance testing with representative personas
Phase 4	Month 7	Mock Scenario Execution • Vulnerability disclosure event requiring rapid exposure assessment • End-of-life notification requiring replacement planning • Suspected counterfeit detection requiring supply chain traceability • CIP-013 audit preparation requiring evidence compilation • Continuous logging of system performance and participant feedback
Phase 5	Month 8	Evaluation and Iteration • Quantitative metrics vs. baseline: time savings, end-of-life visibility, detection effectiveness • Qualitative feedback collection on usability, reliability, and value delivery • Companion Quality Assurance Framework assessment of infrastructure and cognitive AI risks • Gap identification and remediation planning
Phase 6	Month 9	Transition Planning • Production readiness assessment across technical, organizational, and regulatory dimensions • Scaling strategy for next utilities and broader adoption timeline • ERT Companion integration planning documentation • Broader deployment roadmap covering technology evolution and industry adoption milestones

Implementation Considerations

Early Adopter Characteristics

Successful pilot execution requires careful selection of volunteer utilities that exhibit characteristics conducive to learning and validation. Procurement and engineering sophistication prove essential—utilities with mature supply chain risk management processes, experienced procurement teams, and well-documented vendor management programs can engage more effectively with deployment teams and provide meaningful feedback on system capabilities.

CIP-013 audit experience provides strong motivation. Utilities that have completed recent CIP-013 audits understand the documentation requirements and can validate whether automated evidence compilation meets audit expectations. Those facing upcoming CIP-013 audits are particularly motivated to invest effort in capabilities that could streamline future audit preparation.

Supply chain risk incidents create urgency. Utilities that have experienced supply chain security issues—counterfeit components, vulnerable firmware, vendor compromises—immediately grasp the value proposition and are motivated to implement capabilities that prevent recurrence. These utilities can also contribute realistic threat scenarios to pilot testing.

Executive sponsorship from both procurement and engineering leadership ensures that pilot activities receive appropriate organizational support. Supply chain risk management necessarily spans organizational boundaries, requiring coordination across procurement, engineering, IT, security, and compliance functions. Executive sponsorship helps navigate these organizational complexities.

Perhaps most critically, early adopters must approach the pilot as a collaborative development effort rather than expecting a polished, finished product. They should be willing to engage honestly about what works and what does not, tolerate rough edges in exchange for being first to benefit from new capabilities, and actively participate in shaping the tools' evolution through the steering committee process.

Resource Requirements

Pilot execution requires resource commitments from all participants. The volunteer utility typically commits 3–4 full-time equivalents over the nine months, including procurement managers, engineering leads, IT architects, and security analysts who can validate system outputs against operational reality. The utility IT team provides access to procurement, inventory, configuration management, and operations/maintenance systems, coordinates with internal security organizations, and supports the development and testing of data integration.

The program will engage subject-matter experts in CIP-013 supply chain risk management to validate that system capabilities align with regulatory intent. As the program demonstrates value, engagement with NERC and Regional Entity staff on lessons learned will be a natural next step.

Eclectic Technologies provides technical development resources, including data integration, AI agent implementation, multi-agent coordination frameworks, security architecture design, and deployment support across all pilot phases. The steering committee provides oversight through in-kind contributions of participant time, maintaining lightweight governance that avoids creating administrative burden before value has been demonstrated.

For utilities deploying both ERT Companion and SCRM Companion, coordinated deployment reduces total resource requirements. The Data Source Integration Toolkit works for both systems. The deployment team's expertise applies to both installations. Governance and steering committee activities cover both initiatives. This synergy provides efficiency incentives for joint deployment while preserving the option of sequential implementation if resources or priorities dictate otherwise.

Success Metrics

Pilot success will be evaluated across multiple dimensions.

Technical success requires demonstration that SCRM agents can be successfully deployed in real utility environments, integrate effectively with diverse procurement and engineering systems, and provide reliable supply chain intelligence. Vulnerability assessment time should decrease from days or weeks to hours or minutes. End-of-life component visibility should improve from annual assessments to continuous monitoring. Counterfeit detection capabilities should extend from point-of-receipt inspection to supply chain monitoring across procurement, deployment, and operations phases.

Operational success means that procurement, engineering, and security teams experience tangible benefits in their supply chain risk management activities. CIP-013 compliance documentation becomes less burdensome. Emergency vulnerability response becomes faster and more comprehensive. Strategic asset management becomes more proactive. Procurement decisions incorporate real-time risk intelligence.

Regulatory success requires that automated supply chain risk management maintain or improve compliance with CIP-013 requirements. Auditors should find that supply chain security documentation is comprehensive, up to date, and traceable to authoritative sources. The approach should serve as a model for other utilities to strengthen their CIP-013 compliance programs.

Long-term sustainability success requires demonstration that the governance model functions effectively, that knowledge sharing through the steering committee and among participating utilities produces genuine value for participants, and that the intellectual property model supports both continued development and broad industry adoption. The program should create documentation, templates, and best practices that enable efficient scaling to additional utilities beyond the pilot phase. Integration with ERT Companion deployments should demonstrate that the two systems deliver synergistic value that exceeds the sum of their individual capabilities.

Success Metrics at a Glance

- **Technical:** Vulnerability assessment time from days to minutes; end-of-life visibility continuous; counterfeit detection across full supply chain lifecycle
- **Operational:** Tangible benefits for procurement, engineering, and security teams; reduced CIP-013 documentation burden; more proactive asset management
- **Regulatory:** CIP-013 documentation comprehensive, current, and traceable; pilot approach serves as model for broader industry adoption
- **Sustainability:** Effective governance, knowledge sharing through the steering committee and among participating utilities, and IP model supporting broad adoption; demonstrated ERT Companion synergy

Conclusion and Path Forward

The SCRM Companion Agent system represents a strategic opportunity to transform supply chain risk management for critical infrastructure through the integration of artificial intelligence. By providing continuous visibility into hardware and software bills of materials, enabling rapid vulnerability exposure assessment, supporting proactive end-of-life component management, and automating compliance documentation, the system addresses both operational risk reduction and regulatory compliance requirements.

The carefully structured pilot program, using mock-scenario methodology, enables comprehensive validation before production deployment. The protective mechanisms of no operational impact, full rollback capability, and staged validation allow rigorous testing without jeopardizing supply chain security posture or regulatory compliance. The governance framework balances technical excellence through Eclectic Technologies's development, domain expertise through ICS supplier colleague participation, and operational grounding through volunteer utility participation. Broader industry coordination through EEI and regulatory validation through NERC involvement are objectives the program will pursue as pilot results are established.

The multi-agent architecture provides capabilities that scale from tactical vulnerability response to strategic asset management. Individual utilities benefit from comprehensive supply chain intelligence. The industry as a whole benefits from shared knowledge about effective supply chain risk management approaches, creating rising standards that improve the security posture of critical infrastructure broadly.

The SCRM Companion system complements the ERT Companion system, with both initiatives benefiting from shared infrastructure, coordinated governance, and common deployment expertise. Utilities can implement both systems concurrently for comprehensive compliance automation and operational intelligence, or sequentially as resources and priorities dictate. The Data Source Integration Toolkit serves both systems, reducing total deployment effort and enabling cross-system validation.

Success in pilot deployment creates multiple pathways forward. The SCRM Companion establishes precedent for AI-enabled supply chain intelligence in critical infrastructure, informing broader adoption across other infrastructure sectors. The multi-agent architecture demonstrates that complex supply chain risk management can be decomposed into specialized functions that collaborate effectively. The governance model creates mechanisms for industry-wide knowledge sharing and adoption, with a pathway toward NERC and EEI engagement as demonstrated value builds the case for broader ERO Enterprise participation.

Immediate Next Steps

1. **Issue Call for Participants:** Distribute announcement through the steering committee's ICS supplier and utility networks seeking volunteer utilities

2. **Finalize Steering Committee:** Confirm composition with Eclectic Technologies colleagues, ICS supplier participants, and early-adopter utility representatives, and convene inaugural meeting
3. **Initiate Phase 1 Planning:** Begin pilot design activities with selected early adopter utilities, including MOU drafting and mock scenario development
4. **Coordinate with ERT Companion Program:** Identify utilities deploying both systems and develop coordinated deployment plans to realize shared infrastructure efficiencies

Contact Information

For additional information about this pilot program or to express interest in participation, please contact:

Tim Roxey

Eclectic Technologies

Email: tim.roxey@gmail.com

Phone/Signal: 410.474.9240